OrderRace-Notiz - K1: Fido2-Login

Zusammenfassung:
OrderRace-Benutzerkonten können so konfiguriert werden, dass ein Login nur mit einem zweiten Faktor auf Basis von WebAuthn mit Hilfe eines Fido2-Sticks möglich ist.

Warum sind Passwörter nicht (mehr) gut genug?

Passwörter sind ein “geteiltes Geheimnis”: Sie und ein Automat oder Server müssen es kennen. Es sollte aber reichen, wenn nur Sie es kennen oder besitzen. Denn:

- dem Automaten/Server kann das Geheimnis gestohlen werden. Dann haben Sie weitere Mitwisser. Gegen diesen Diebstahl hilft die Technik der Speicherung mittels Hash-Algorithmus und Salt nicht perfekt.
- bei der Eingabe des Passwortes werden Sie vielleicht beobachtet, Ihre Tastatureingaben werden mitgeschnitten oder auf dem Transport vom Browser über das Internet zum Server gibt es Mitleser. Die Verschlüsselungs-Techniken SSL (heute TLS genannt) und HTTPS sind nur bedingt ein Schutz dagegen.

Zur Anmeldung (zum Nachweis Ihrer Identität) muss es reichen, dass Sie beweisen, dass Sie ein Geheimnis kennen, ohne das Sie es offenbaren. Genau das machen Fido2 und WebAuthn.

Geklaute Passwörter und damit gestohlene Identitäten sind keine Theorie sondern heute Alltag. Daher braucht es Alternativen oder Ergänzungen zu Passwörtern als Berechtigungsnachweis (Englisch credential) oder Login-Faktor.

2-Faktor-Authentifizierung_

Sich mit einer öffentlich bekannten Konto- oder Kunden-Nr. und einem Kennwort anzumelden, wird 1-Faktor Authentifizierung genannt (mit nur einem Beweis-Argument). Mit der 2-Faktor-Authentifizierung wird der Identitätsnachweis eines Anwenders mittels zweier unterschiedlicher und unabhängiger Faktoren bezeichnet. Da Kennworte heute als Schwachpunkt gelten, ergänzen viele Dienste heute das Kennwort um weitere Faktoren. Die EU schreibt mit der PSD2-Richtlinie seit 2019 die 2-Faktor-Authentifizierung für Bankkunden zwingend vor. Praktizierte Beispiele für 2-Faktor-Authentifizierung sind SMS-TANs, Einmal-Kennwort-Generatoren oder diverse Formen von Biometrie. All diese 2-Faktor-Authentifizierungsmethoden haben ihre Vor- und Nachteile. Wir haben uns für Fido2/Webauthn entschieden.

Was ist ein Fido2-Stick?

Ein Fido2-Stick ist ein Kleinstcomputer zum Nachweis Ihrer Identität. In dieser Funktion kommt er einem Personalausweis gleich - verbunden mit darauf gespeicherten Rechten, bestimmte Dienste zu benutzen (Schlüsselspeicher). Er kommuniziert via USB, Bluetooth oder NFC mit Ihrem Computer oder Tablet. Ein Fido2-Stick kann viele Berechtigungsnachweise für verschiedene Dienste enthalten. Alle Googlemitarbeiter haben z.B. zwei Fido2-Sticks, um sich bei der Arbeit anzumelden. Einige Microsoftdienste können mit Fido2 autorisiert benutzt werden.

Es handelt sich um einen offenen Standard (alle technischen Details sind öffentlich zugänglich). Jeder kann Fido2/WebAuthn ohne Lizenzkosten verwenden. Erfolgreiche Angriffe auf diese Verschlüsselungstechnik sind bis heute (März 2020) nicht bekannt. Der Fido2-Standard erlaubt es, wahlweise auf alle anderen Login-Berechtigungsnachweise zu verzichten (wie an der Haustür: Login mit nur einem Schlüssel). Ein Türschlüssel kann mit Gummi und Feile kopiert werden - er zeigt sein Geheimnis (den Bart) offen zugänglich. Ein Fido2-Stick enthält für jeden Dienst ein anderes Geheimnis (einen sogenannten “private Key”, also eine sehr große Zahl mit z.B. Hundert Stellen), das er selbst erzeugt hat. Die verbreitete bequeme Unsitte, für verschiedene Dienste dasselbe Kennwort zu verwenden ist mit Fido2 nicht möglich. Dieses Geheimnis verlässt den Fido2-Stick zu keinem Zeitpunkt (Der Versuch, die Elektronik “aufzubasteln” soll zur Zerstörung des Speichers führen). Zu jedem Geheimnis erzeugt der Stick einen öffentlichen Schlüssel, der vom Server-Dienst gespeichert wird. Ein Fido2-Stick kann nach heutigem Wissen mit praktikablem Aufwand nicht kopiert werden. Für den Fall von Verlust und Defekt sollten daher mindestens zwei Fido2-Sticks vorhanden und angemeldet werden.

Die Verwendung eines Fido2-Sticks wird wahlweise mit einer PIN abgesichert (damit ein geklauter Stick nicht missbraucht werden). Aufwendigere Fido2-Sticks haben einen Fingerabdruck-Sensor.

Jeder Fido2-Stick hat ein Lampe mit der er signalisiert, das er jetzt von einer Software verwendet werden will. Zur Bestätigung muss innerhalb weniger Sekunden der Knopf gedrückt oder der Fingerprint-Sensor betätigt werden, sonst bricht dieser Vorgang ab.

Technische Voraussetzungen des Arbeitsplatzes

1) Windows 10 (Version 1903 und folgende). Für andere Betriebssysteme liegen noch keine Erfahrungen vor.
2) Als Browser sind die aktuellen Versionen von Chrome, Firefox und Opera möglich
3) zwei Fido2-Sticks (freier USB-Port für Fido2-Sticks), oder TPM-PC (mit Fingerprint-Sensor), wir empfehlen jedoch die Fido2-Sticks
4) Einstieg über TLS/SSL/HTTPS (Wenn Ihre Anmeldung aus Ihren Favoriten mit http://.. statt https://.. gestartet wird, wird Fido2 nicht funktionieren)
5) Javaskript darf nicht gesperrt sein

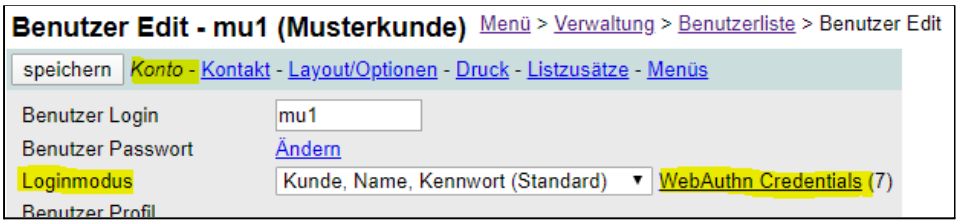
Getestete FIDO2-Geräte (Kosten 10-35 Euro im Februar 2020):

- HyperFIDO Mini (U2F Security Key)
- HyperFIDO Pro Mini U2F/FIDO2/HOTP Sicherheitsschlüssel
- Solo Tap - Sicherheitsschlüssel Zwei-Faktor Authentifizierung, U2F und FIDO2 - USB-A + NFC
- Yubico Security Key - U2F and FIDO2, USB-A

Wir empfehlen, je Anwender wenigstens zwei Fido2-Sticks zu besorgen. Ob Sie zweimal die gleichen oder lieber unterschiedliche Geräte nutzen wollen, bleibt Ihnen überlassen.

Registrieren des Fido2-Sticks in OrderRace

Zum Anmelden des Fido2-Sticks stecken Sie den Stick in einen USB-Port Ihres PCs/Laptops. Melden Sie sich in OrderRace an und springen über Verwaltung / Benutzerliste auf Ihren Benutzer. Klicken Sie im Reiter Konto hinter Loginmodus den Button "WebAuthn Credentials":

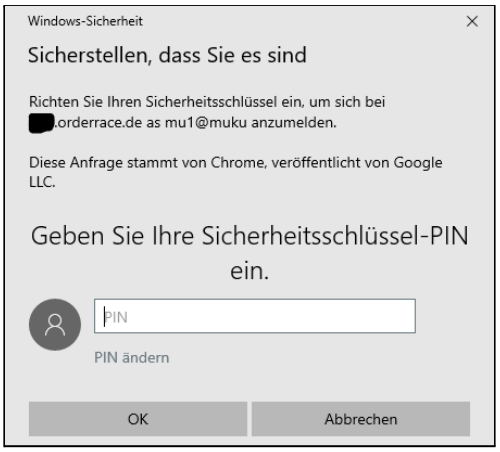


(Diese Funktion steht nur zur Verfügung, wenn der Spediteur bereits auf kryptographische Passwörter umgestellt wurde.)

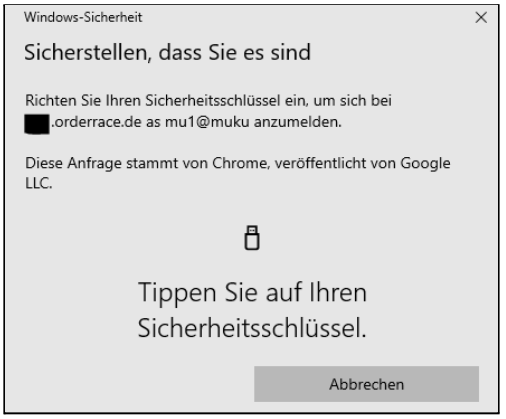
Sie können hier nun bis zu 10 Credentials (Schlüsselpaare) je Benutzer erstellen. Je Credential kann ein kurzer Infotext erfasst werden, um die Fido2-Sticks zu identifizieren ("Stick von Hans", "das blaue Dings Nr 3"...). Exemplarisch haben wir hier bereits 7 Credentials hinterlegt:

Klicken Sie auf den Button "WebAuthn Credential hinzufuegen (derzeit registriert: x von max. 10)", Sie werden danach zu einer PIN-Eingabe aufgefordert (Die PIN ist für den ganzen Fido2-Stick und muss bei der ersten Benutzung zweimal eingegeben werden, danach nur noch je einmal zur Bestätigung):

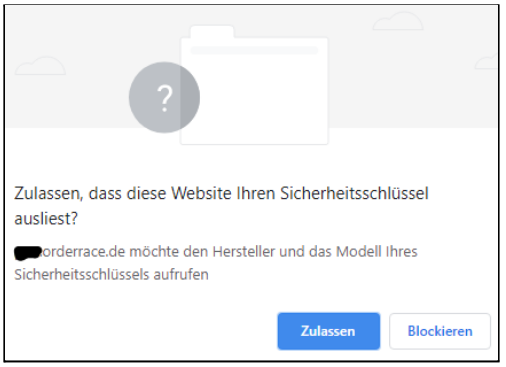
Geben Sie nun Ihre PIN ein, bzw. bei der ersten Nutzung des Sticks vergeben Sie eine neue PIN, wiederholen Sie diese und klicken anschließend auf OK.



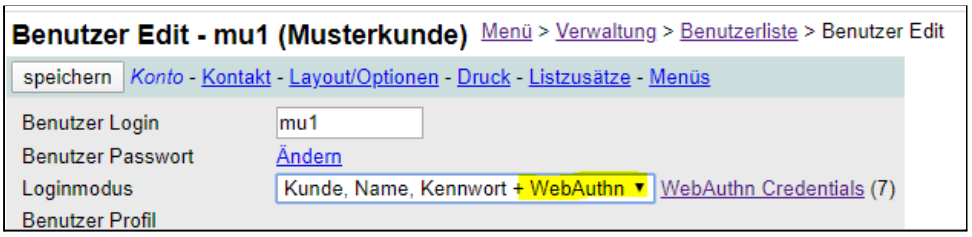
Danach werden Sie dazu aufgefordert, auf Ihren Sicherheitsschlüssel zu tippen (dieser sollte blinken)



Ihr Browser fragt eventuell nach, ob der Zugriff erlaubt werden soll.

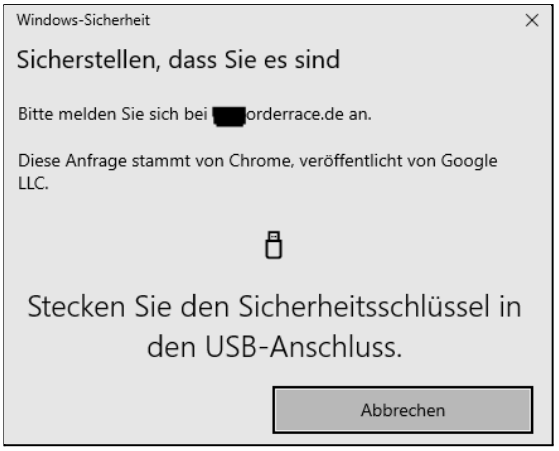


Die Funktion “löschen” wird verwendet wenn der Fido2-Stick nicht mehr zum Anmelden bei OrderRace verwendet werden soll (Verlust).
Sind die Credentials erstellt, ist es noch notwendig den Benutzer-Login auf diesen Modus umzustellen:

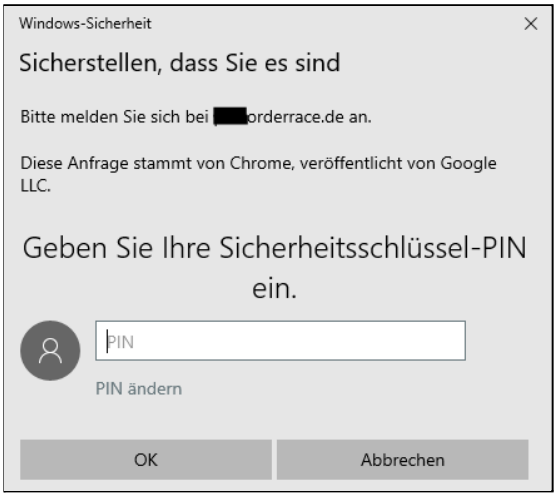


Anmeldung mit der 2-Faktor-Authentifizierung

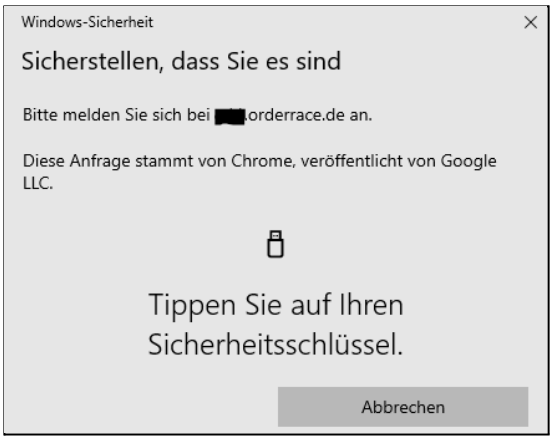
Zur Anmeldung reichen nun Ihre bisherigen Anmeldedaten nicht mehr aus. Sie benötigen einen der angemeldeten Sticks und werden nach Ihrer bislang gewohnten Anmeldung dazu aufgefordert den Fido2-Stick einzusetzen:



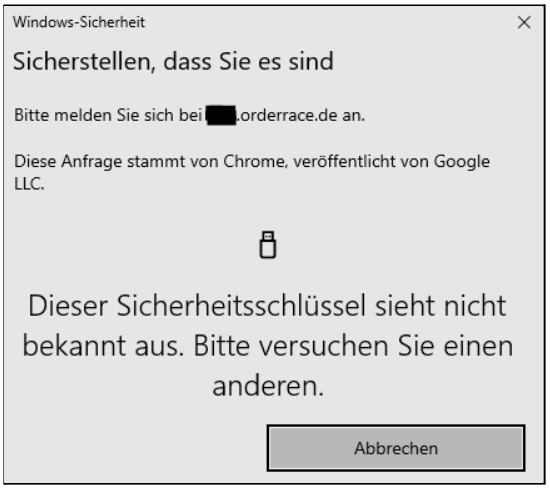
und nach der PIN gefragt (falls der Stick eine PIN hat)



Nach Eingabe der PIN werden Sie dazu aufgefordert, auf Ihren Fido2-Stick zu tippen (blinkt wieder). Dafür haben Sie einige Sekunden Zeit bevor diese Aufforderung abbricht und Sie erneut den PIN eingeben müssen.



Sollten Sie einen für diese Anwendung ungültigen Fido2-Stick verwenden, werden Sie darauf hingewiesen.



Anmerkungen:

Ihr Spediteur ist im Notfall immer in der Lage, Ihren Zugang auf den alten Login, ohne WebAuthn / Fido2 zurückzustellen.

Bei Verlust des Sticks sollten/müssen Sie das Credential in den Benutzerdaten löschen.

Ein Fido2-Stick kann mehrfach an einem Benutzerkonto angemeldet werden. Es gibt aber keinen Grund dazu. Wenn Sie es probehalber machen, sollte die Dublette gelöscht werden.

Copyright Daum Datentechnik Retgendorf